

CISSP Printable Practice Exam 25 - Domain 1 - Security and Risk Management

Practice Exam 04 - Domain 1

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP4-001)

Scenario: A security manager is asked to lead a specialized investigation involving techniques the manager has never practiced. Executives expect an immediate conclusion and do not realize that the manager lacks the required expertise.

What is the manager's BEST course of action?

- A. Accept the assignment silently and learn the techniques while handling the evidence
- B. Disclose the limitation and obtain appropriately qualified assistance while preserving responsibility and confidentiality
- C. Decline all involvement and publicly explain why management selected the wrong person
- D. Issue a preliminary conclusion based only on experience from unrelated investigations

Question 2 (CISSP4-002)

Scenario: An employee sends an accurate compensation report to an external recipient who has no authorization to view it. The report remains available to authorized staff and is not modified.

Which security objective has been MOST directly compromised?

- A. Availability
- B. Authenticity
- C. Integrity
- D. Confidentiality

Question 3 (CISSP4-003)

Scenario: A media enterprise has approved a very low appetite for interruptions to its live broadcasting service but a moderate appetite for delays in an internal archival process. Both areas request the same limited resilience funding.

How should the governance committee use this information?

- A. Prioritize treatments according to business impact and the approved appetite for each service
- B. Divide funding equally because governance should not distinguish between business objectives
- C. Let technical teams redefine risk appetite after selecting their preferred solutions
- D. Fund the archival process first because it accepts more risk

Question 4 (CISSP4-004)

Which 2 arrangements BEST support sound security governance? Select 2 of the 5 options below.

- A. Business leaders own material risk decisions within delegated authority
- B. Control operators approve their own unresolved exceptions without oversight
- C. The security team accepts every enterprise risk because it provides technical advice
- D. An oversight function can challenge risk decisions and report significant issues through an appropriate channel

E. System administrators define organizational risk appetite independently

Question 5 (CISSP4-005)

Scenario: A national retailer begins a major transformation that will change customer services, operating processes, partners, and data flows. Security is scheduled to review the program only after contracts and designs are finalized.

What should the CISO recommend?

- A. Delay security involvement until implementation reveals which risks actually occur
- B. Let each supplier determine the retailer's acceptable business risk
- C. Include security, privacy, legal, and risk stakeholders in governance and design decisions from the outset
- D. Require one identical technical control for every process before analyzing business needs

Question 6 (CISSP4-006)

Scenario: A regional manager wants to approve an exception whose potential impact exceeds the manager's documented authority. The exception supports an important launch, and delaying the decision could affect revenue.

What should the security adviser recommend NEXT?

- A. Allow the manager to approve it because revenue impact expands delegated authority
- B. Escalate the documented risk and business rationale to the authorized decision-maker
- C. Approve the exception on behalf of the manager to keep the launch on schedule
- D. Remove the impact estimate so the request fits the manager's authority

Question 7 (CISSP4-007)

Scenario: After a suspected payment-data incident, a merchant's agreement requires an independent investigation under an industry security program. No prosecutor or regulator has initiated the review.

What type of investigation is MOST directly described?

- A. An industry-standards or contractual investigation
- B. A criminal prosecution
- C. An administrative licensing hearing
- D. A civil lawsuit for damages

Question 8 (CISSP4-008)

Scenario: A transportation company has not reviewed its information security policy for six years. Since approval, the company has entered new jurisdictions, acquired two businesses, and changed its operating model.

Which action is MOST appropriate?

- A. Keep the policy unchanged because its original approval remains permanent
- B. Let system administrators rewrite and approve the policy without business input
- C. Perform a governed review, update affected requirements, obtain authorized approval, and communicate the changes
- D. Replace the policy with informal guidance that each business unit may interpret independently

Question 9 (CISSP4-009)

Scenario: A delivery company collected location data to route drivers safely. Marketing now

wants to use the historical data to build individual lifestyle profiles, a purpose not described when the information was collected.

What should privacy leadership require BEFORE approving the new use?

- A. Approval by marketing alone because the organization already possesses the data
- B. Immediate profiling before retention periods remove older records
- C. A technical copy of the data stored under a different filename
- D. Assessment of purpose compatibility, legal basis, transparency, necessity, retention, and individual rights

Question 10 (CISSP4-010)

Scenario: A specialty manufacturer relies on a confidential formula that derives value from not being generally known. The company wants to strengthen the legal and organizational basis for treating it as a trade secret.

Which 2 actions are MOST appropriate? Select 2 of the 5 options below.

- A. Publish the formula while labeling it confidential
- B. Restrict access according to business need and maintain evidence of authorized handling
- C. Avoid identifying the information internally so employees are not alerted to its value
- D. File the formula as a trademark without controlling disclosure
- E. Use suitable confidentiality agreements and communicate continuing duties to authorized recipients

Question 11 (CISSP4-011)

Scenario: A research institute plans to acquire specialized security equipment from another country. Procurement assumes that only the seller must consider cross-border controls and that the buyer has no import responsibilities.

What should the institute determine before completing the purchase?

- A. Whether only the equipment's color affects import eligibility
- B. Whether classification, destination, end use, recipient, customs, licensing, or other import requirements apply
- C. Whether the seller is willing to omit the equipment description from shipping records
- D. Whether internal approval can replace government authorization

Question 12 (CISSP4-012)

Scenario: An incident investigator confirms that protected records were accessed by an unauthorized account. The facts may trigger several contractual and statutory duties, but the investigator has no authority to interpret the governing law.

What should the investigator do NEXT?

- A. Preserve and report the verified facts, then coordinate with authorized legal and business stakeholders on applicable duties
- B. Declare that every possible law was violated and notify all jurisdictions immediately
- C. Withhold the findings until the investigator can independently provide a legal opinion
- D. Delete evidence that does not support the first suspected legal theory

Question 13 (CISSP4-013)

An illustrative asset is valued at \$500,000. A loss event would create a 40 percent exposure, and the event is expected once every four years. What is the annualized loss expectancy?

- A. \$20,000
- B. \$40,000
- C. \$50,000
- D. \$200,000

Question 14 (CISSP4-014)

Scenario: A wholesaler continues offering an online service but adds governance and preventive safeguards that materially reduce the likelihood of a defined loss scenario. The organization retains the remaining exposure.

Which risk treatment strategy is being used?

- A. Acceptance without treatment
- B. Avoidance
- C. Transfer
- D. Mitigation

Question 15 (CISSP4-015)

Scenario: A healthcare billing process has a high level of exposure before safeguards are considered. After preventive and detective controls are applied, the remaining exposure is rated moderate.

What does the moderate rating represent?

- A. Transferred risk owned entirely by a third party
- B. Residual risk remaining after controls are considered
- C. Inherent risk before safeguards are evaluated
- D. Risk appetite approved for every business process

Question 16 (CISSP4-016)

Which 2 activities should occur as foundational parts of a structured threat-modeling exercise? Select 2 of the 5 options below.

- A. Define the system scope, assets, data flows, entry points, and trust boundaries
- B. Purchase a security product before identifying the threats it should address
- C. Enumerate and analyze threats using a consistent methodology, then prioritize them by risk
- D. Assume the design is safe when no prior incident has been reported
- E. Exclude business stakeholders because threat modeling is only a coding activity

Question 17 (CISSP4-017)

Scenario: Ongoing monitoring shows that a critical records provider has changed ownership, replaced key subcontractors, and suffered repeated service failures. The provider passed due diligence three years ago.

What should the vendor risk owner do FIRST?

- A. Perform a risk-based reassessment and evaluate treatment, escalation, and contractual options
- B. Rely on the original review because completed due diligence remains valid for the contract term
- C. Ignore ownership and subcontractor changes unless a confirmed data loss occurs
- D. Renew the agreement early to demonstrate confidence in the provider

Question 18 (CISSP4-018)

Scenario: A university applies the same lengthy security questionnaire and contract schedule to a catering supplier with no system access and to a provider that hosts sensitive research data. Reviews are slow, and high-risk relationships receive no additional scrutiny.

Which improvement would be MOST effective?

- A. Eliminate supplier reviews so procurement can focus on delivery performance
- B. Use price as the only factor for determining security requirements
- C. Create risk tiers based on access, data sensitivity, criticality, and dependency, with requirements matched to each tier
- D. Apply the low-risk supplier requirements to every relationship for consistency

Question 19 (CISSP4-019)

Scenario: A business impact analysis finds that a laboratory reporting process can be interrupted for no more than ten hours before consequences become unacceptable. The proposed recovery strategy is expected to restore the process in fourteen hours.

What should the continuity manager conclude?

- A. The strategy is acceptable because recovery objectives are optional estimates
- B. The fourteen-hour estimate is a recovery point objective for data loss
- C. The process should be removed from the continuity plan
- D. The strategy does not meet the maximum tolerable downtime and requires revision or additional capability

Question 20 (CISSP4-020)

Scenario: An employee transfers from payroll administration to facilities planning. The employee receives new access but retains all payroll privileges because the account was not included in the transfer workflow.

What control improvement is MOST appropriate?

- A. Retain all prior access in case the former team needs occasional assistance
- B. Trigger a role-change process that reviews old and new access, conflicts, agreements, training, and ownership approvals
- C. Create a second identity so old privileges remain available but less visible
- D. Let the employee decide which payroll privileges are still necessary

Question 21 (CISSP4-021)

Scenario: A consultant completes an engagement involving confidential design material. The project manager confirms that deliverables are accepted, but no one has addressed access, borrowed equipment, local copies, or continuing confidentiality duties.

Which action should occur NEXT?

- A. Execute the documented offboarding process, including access removal, asset return, authorized data disposition, and confirmation of surviving obligations
- B. Keep access active for convenience in case another project begins later
- C. Allow the consultant to retain every local copy as a professional portfolio
- D. Delete all organizational records of the engagement after deliverable acceptance

Question 22 (CISSP4-022)

An awareness assessment shows that employees recognize suspicious messages but hesitate to report them because they fear punishment for mistakes. Which 2 program actions would BEST address the finding? Select 2 of the 5 options below.

- A. Stop measuring reporting behavior so poor results are not visible

- B. Provide targeted practice that includes the exact reporting process and expected response
- C. Publish the names of employees who made reporting errors
- D. Promote a clear, accessible, and supportive reporting channel with appropriate feedback
- E. Replace awareness activities with a statement that employees are solely responsible for every incident

Question 23 (CISSP4-023)

Scenario: A financial cooperative has completed its business impact analysis and identified required recovery timeframes, minimum staffing, external dependencies, and acceptable manual workarounds. Several continuity strategies differ greatly in cost and capability.

How should leadership select the strategy?

- A. Choose the most expensive option because cost proves resilience
- B. Let the technology team select based only on preferred tools
- C. Compare each option with BIA requirements, risk appetite, dependencies, feasibility, and total cost
- D. Choose the slowest option because longer recovery creates more planning time

Question 24 (CISSP4-024)

Scenario: During a prolonged outage, different managers send conflicting updates to employees, customers, regulators, and suppliers. The normal email service is unavailable, and no one knows who may approve public statements.

Which improvement would BEST address the continuity weakness?

- A. Allow every manager to publish independent estimates so communication remains fast
- B. Wait until all services recover before providing any stakeholder update
- C. Use only the failed email service so all communications remain in one system
- D. Create and exercise a crisis communication plan with authorized roles, stakeholder contacts, alternate channels, approval paths, and message validation

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP4-001) - Correct: B

Professional competence requires an honest disclosure of relevant limitations and the use of qualified assistance when necessary. The manager can remain accountable while ensuring that specialized work is performed properly. Learning on live evidence risks error, public criticism may breach confidentiality, and an unsupported conclusion would mislead decision-makers.

Question 2 (CISSP4-002) - Correct: D

Confidentiality limits information disclosure to authorized parties, so delivery to an unauthorized recipient is a direct violation. The report remained accurate and accessible, leaving integrity and availability intact. Authenticity addresses whether an identity or item is genuine rather than whether the recipient was permitted to see the content.

Question 3 (CISSP4-003) - Correct: A

Risk appetite expresses executive direction about the types and amounts of risk the organization is willing to pursue or retain. Combined with business impact, it should guide treatment priority and escalation. Equal allocation may ignore strategic needs, technical teams should not redefine executive appetite, and greater willingness to accept archival delay does not justify prioritizing it over the low-appetite service.

Question 4 (CISSP4-004) - Correct: A, D

Accountable business leaders should own material risk decisions, while an oversight function provides independent challenge and escalation. Control operators approving their own exceptions weakens objectivity. Security advisers do not automatically own business risk, and system administrators do not set enterprise risk appetite without delegated governance authority.

Question 5 (CISSP4-005) - Correct: C

Early integration lets the program identify obligations, dependencies, risk ownership, and treatment needs while strategic choices can still be changed. Waiting creates costly late-stage findings, suppliers cannot set the retailer's appetite, and a uniform control imposed before analysis may not address differing risks or objectives.

Question 6 (CISSP4-006) - Correct: B

Decision rights remain governed by delegated authority even when a business deadline is important. The adviser should provide the authorized owner with the risk, rationale, options, and urgency needed for an informed decision. Neither commercial pressure nor altered documentation gives the manager or adviser additional acceptance authority.

Question 7 (CISSP4-007) - Correct: A

The investigation arises from an industry program and contractual agreement, so its scope and evidence requirements are primarily driven by those obligations. A criminal prosecution requires government action, an administrative hearing involves a regulatory authority, and a civil lawsuit is a judicial dispute between parties.

Question 8 (CISSP4-008) - Correct: C

Material changes in law, structure, and operations can invalidate policy assumptions. A controlled lifecycle includes review, stakeholder input, revision, authorized approval, communication, and later maintenance. Original approval is not permanent, technical personnel alone should not set enterprise direction, and informal guidance cannot replace a mandatory policy.

Question 9 (CISSP4-009) - Correct: D

Possessing personal data does not automatically authorize every later use. The organization should assess whether the new purpose is compatible and lawful, whether people need additional information or choices, and whether the processing is necessary and proportionate. Marketing approval, urgency, or copying the data does not resolve those obligations.

Question 10 (CISSP4-010) - Correct: B, E

Trade secret protection depends on secrecy and reasonable measures to preserve it. Need-based access, accountable handling, confidentiality agreements, and clear duties support that objective. Public disclosure destroys secrecy, failing to identify sensitive information weakens protection, and trademark registration does not protect a confidential formula from disclosure.

Question 11 (CISSP4-011) - Correct: B

The importing organization must identify the classification, end use, parties, customs rules, licenses, and other authorizations that apply in relevant jurisdictions. A seller's duties do not eliminate the buyer's obligations. Incomplete shipping records or internal approval cannot substitute for accurate declarations and required government authorization.

Question 12 (CISSP4-012) - Correct: A

The investigator should establish and preserve reliable facts within the assigned role, while qualified and authorized stakeholders determine legal and contractual consequences. Broad unsupported conclusions can produce inaccurate action, waiting for personal legal expertise delays response, and deleting contrary evidence compromises integrity and defensibility.

Question 13 (CISSP4-013) - Correct: C

The single loss expectancy is $\$500,000 \times 0.40$, or $\$200,000$. One event every four years gives an annualized rate of occurrence of 0.25. Multiplying $\$200,000$ by 0.25 produces an annualized loss expectancy of $\$50,000$. The other values omit or misapply one of the inputs.

Question 14 (CISSP4-014) - Correct: D

Mitigation reduces the likelihood or impact of a risk while the underlying activity continues. Avoidance would discontinue the activity, transfer would allocate specified consequences to another party, and untreated acceptance would retain the exposure without the additional safeguards described.

Question 15 (CISSP4-015) - Correct: B

Residual risk is the exposure that remains after the effects of controls and other treatments are considered. The high pre-control rating is inherent risk. A residual rating does not show that risk was transferred, nor is it the same as the organization's broader risk appetite.

Question 16 (CISSP4-016) - Correct: A, C

Threat modeling begins with an accurate understanding of scope, assets, flows, entry points, and trust boundaries. A consistent methodology then helps identify and prioritize relevant threats. Selecting products first reverses the analysis, absence of known incidents is not evidence of safety, and business context is needed to evaluate impact and priorities.

Question 17 (CISSP4-017) - Correct: A

Material changes and repeated failures can invalidate prior assumptions, so the organization

should reassess current exposure and use available treatment and contractual mechanisms. Due diligence is ongoing rather than permanent. Waiting for confirmed loss is reactive, and early renewal would reduce leverage before the changed risk is understood.

Question 18 (CISSP4-018) - Correct: C

Risk tiering directs assessment effort and contractual safeguards toward relationships with greater access, sensitive data, criticality, or dependency. It also avoids unnecessary burden on low-risk suppliers. Eliminating reviews, using price alone, or applying the weakest requirements universally would leave material supply-chain exposure insufficiently governed.

Question 19 (CISSP4-019) - Correct: D

Maximum tolerable downtime is the disruption limit beyond which the business impact becomes unacceptable. A strategy expected to recover after that limit does not meet the requirement and must be revised. The value concerns outage duration rather than data loss, and removing the process from the plan would hide rather than resolve the gap.

Question 20 (CISSP4-020) - Correct: B

Internal transfers require controlled review just as onboarding and departure do. Prior access should be removed unless a current, approved need exists, and new responsibilities may require updated training or agreements. Retained or hidden privileges create accumulation risk, and employees should not approve their own access.

Question 21 (CISSP4-021) - Correct: A

Contractor offboarding should promptly remove access, recover assets, govern copies and records, and reinforce obligations that continue after the engagement. Convenience does not justify dormant access, portfolio use requires explicit authorization, and deleting organizational records may violate business, evidentiary, or retention needs.

Question 22 (CISSP4-022) - Correct: B, D

Targeted practice builds the specific reporting skill, while an accessible and supportive channel reduces hesitation and reinforces desired behavior. Hiding results prevents improvement, public blame discourages reporting, and assigning total incident responsibility to employees ignores organizational processes and controls.

Question 23 (CISSP4-023) - Correct: C

Continuity strategy selection should trace to the BIA and balance required capability, dependencies, feasibility, risk direction, and total cost. Price alone does not prove suitability, technology preference ignores broader business needs, and a slower option may fail the established recovery requirements.

Question 24 (CISSP4-024) - Correct: D

A crisis communication plan should define audiences, authorized communicators, approval paths, alternate methods, and validation so messages remain timely and consistent when normal channels fail. Uncoordinated estimates can cause harm, silence may breach obligations and trust, and relying solely on an unavailable channel is not resilient.